

CSS Exam 2025 – Task 09

Introduction

You were asked to analyse a problem installing a secure remote support software provided by a software vendor. As basis for the analysis, an excerpt from an e-mail exchange with the software vendor and the software components are available in the resource section.

Resources

dea0ec73d6e4f7772b358c475dcac280	files.zip	md5sum
563d25145a8eb485bdbbfd5f8b95da97	mail.pdf	md5sum

```
kali# md5sum files.zip
dea0ec73d6e4f7772b358c475dcac280 files.zip
kali#
```

```
kali# md5sum mail.pdf
563d25145a8eb485bdbbfd5f8b95da97 mail.pdf
kali#
```

Goals and Tasks

Analyze the provided data and answer the following questions in a written report.

1. Why is the new software not running? Describe the technical aspects of the problem.
 - The new **remote_v2.exe** is blocked because its digital signature cannot be validated through a complete certificate chain to the trusted UmagDev Root CA.
The AppLocker policy is enabled for executable files and contains an **Allow publisher rule** for: *O=UMAGDEV LTD, L=BERN, S=BERN, C=CH*.
 - The old **remote_v1.exe**, which works, contains both the code-signing certificate and the required intermediate certificate. Its certificate chain is:

UmagDev RootCA (OU=Security)
↓
UmagDev IntermediateCA (OU=Security)

↓
UmagDev CodeSigningCert
↓
remote_v1.exe

```
kali# openssl pkcs7 -in v2.pem -print_certs -noout
subject=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Development, CN=UmagDev CodeSigningCert
issuer=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Sec, CN=UmagDev IntermediateCA

kali# openssl pkcs7 -in v1.pem -print_certs -noout
subject=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Security, CN=UmagDev IntermediateCA
issuer=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Security, CN=UmagDev RootCA

subject=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Development, CN=UmagDev CodeSigningCert
issuer=C=CH, ST=Bern, L=Bern, O=UmagDev Ltd, OU=Security, CN=UmagDev IntermediateCA
```

- The UmagDev Root CA is present in the customer's Windows Trusted Root Certification Authorities store. In contrast, **remote_v2.exe** contains only its code-signing certificate. Its issuer is specified as: *CN=UmagDev IntermediateCA, OU=Sec*.

But this intermediate certificate is not included in the executable's signature. Therefore, the system cannot construct a valid certificate chain from the V2 signing certificate to the trusted UmagDev Root CA. As a result, the publisher cannot be successfully validated and the executable does not satisfy the enforced AppLocker publisher rule.

- The email confirms that **remote_v1.exe** worked, **remote_v2.exe** is blocked, and the customer did not make additional changes to the Windows Certificate Store.

2. Briefly explain a maximum of 2 specific, possible causes for the problem.

Cause1:

The vendor did not include the required **UmagDev intermediate CA** certificate in the signature of **remote_v2.exe**. In comparison, **remote_v1.exe** contains the intermediate certificate.

This results in certificate-chain verification failing with:

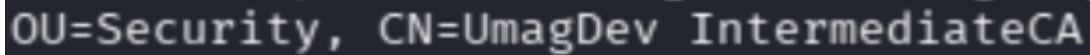
```
PKCS7_verify error
Failed signing certificate chain retrieved from the signature:
```

Cause2:

The **remote_v2.exe** code-signing certificate identifies its issuer as:

```
OU=Sec, CN=UmagDev IntermediateCA
```

whereas the working V1 certificate hierarchy uses:



OU=Security, CN=UmagDev IntermediateCA

This indicates that **remote_v2.exe** was issued using a different or incorrectly configured intermediate CA identity. Combined with the missing intermediate certificate, the client cannot establish the expected trust chain.

3. Briefly describe a maximum of 2 specific measures that the software vendor could take to increase security with regard to the delivery of the software.

Measure 1 – Provide the complete certificate chain

UmagDev should sign releases using a properly configured code-signing certificate and include the required intermediate CA certificate in the Authenticode signature. Before distribution, the vendor should verify that the complete chain can be built to the root CA trusted by customers.

Measure 2 – Improve and verify the signing/release process

UmagDev should implement an automated release validation process that checks every executable's digital signature, certificate chain, issuer information and trust before publication. Code-signing certificates and private keys should also be centrally controlled to prevent inconsistent or incorrectly generated certificates from being used.

Resource:



ICT-2025-Task-9.zip